

Inventory Risk Assessment

Introduction

Today, more than ever, it is necessary for us to have an asset inventory and risk assessment. This is due to the increased interconnectedness of devices, data, and other information technology. Additionally, hackers and bad actors keep getting better daily, using sophisticated and innovative methods and technology to gain access/control of information and devices. This is also relevant to national security in some cases as we have discussed in class. Therefore, this is an important exercise in my opinion.

To create an asset inventory, we must list any asset that has our information, this can include people, hardware, software, data (including physical such as mail, tax documents, etc.), and more depending on relevant categories. Once we have a list, we can go ahead and assess. This is a critical part as it involves understanding the potential threats and vulnerabilities each asset may have. Following which we should continue monitoring. We can also refer to the NIST RMF for this purpose as I did for this assignment (NIST RMF: <https://csrc.nist.gov/projects/risk-management/about-rmf>, 2023).

This dual process of inventory and risk assessment provides a roadmap. It highlights what we have, what is at stake, and what needs protection. Through this methodical approach, we can anticipate potential breaches, safeguard our assets, and have peace of mind.

Overview

Conduct

Methodology:

The risk assessment began with a thorough inventory, wherein each asset, be it digital or tangible, was listed in an organized manner. Mainly drawing inspiration from the NIST RMF standards, I made changes to this to accommodate my personal needs. For example, since this is a personal inventory and assessment, I did not need to get these authorized. However, this might be relevant in business settings.

Documentation:

A digital record was maintained and kept updated during the inventory process to ensure no asset was overlooked.

Categorization

Criteria:

Assets were systematically categorized based on their nature and role. The primary categories included People, Hardware, Software, Data, and Routines (Processes). Wherever necessary, groups were created for highly similar assets. The purpose of this categorization was not just to satisfy the requirements of this exercise but also to help with the risk assessment process.

Identification of Threats/Vulnerabilities

Research:

Class discussions played a crucial role in this part as they made me aware of potential threats and current events. I also was able to utilize my daily routine of following technological and security outlets to keep up with new threats.

Scenario Analysis:

For more personalized assets, especially those in the People and Process categories, potential threat scenarios were brainstormed to understand plausible risks. Past incidents or patterns also played a role in recognizing vulnerabilities for these asset classes.

Asset Prioritization and Valuation:

Valuation Metrics:

Each asset was assigned a value based on its significance and importance, potential replacement cost, or the impact of its compromise on personal and professional levels. Additionally, I also considered how each asset would affect other people whose information I might possess.

Prioritization Criteria:

Assets were then prioritized as Vital, Critical, High, Medium, or Low, based on their value and the potential impact of their compromise.

System Determination:

System Classification:

Systems were recognized as assets that could be grouped by usability. For example, Google Chrome is a system according to me because it allows me to use any webapp such as outlook emails, Gmail, Blackboard for education, banking, etc. As I can perform multiple tasks using this asset, I classified it as a system.

Assets

Person

ASSET NAME: Myself

DESCRIPTION: Self

1. **Confidentiality > High:** I have assigned a disclosure value of \$1,200,000. This represents the potential financial loss from personal information leaks or misuse. Specifically, if I fall victim to threats like social engineering, phishing, or direct hacking. Much of this estimate is the loss of income around \$1,000,000. This value seems lower because I have adjusted it to me moving back to India, where wages are lower compared to the USA. To combat these, my defense measures include a heightened state of alertness, awareness, and both standard to advanced protection parameters. As the frequency of such threats is high, an Annual Rate of Occurrence (ARO) of 0.1 has been assumed. My uncertainty about this threat, based on a mix of experiences and the dynamic nature of these attacks, stands at 0.15. The resultant risk from such threats is approximated to be \$13,800. To further mitigate these risks, I recognize the need for advanced threat protection software and a contingency plan in place to counter any successful breach attempts.

2. Integrity > High: The integrity of my actions and decisions is valued at \$1,500,000. This encompasses the potential harm from being manipulated or drugged which might result in me making decisions or statements that I wouldn't normally make, thus jeopardizing my personal and professional reputation. My lifestyle does not involve many such events. So, I have ascertained an ARO of 0.001 for this category. My preventive measures include being extremely cautious about the company I keep, the locations I visit, and being particular about what I consume in terms of food and drink. Additionally, sharing my location (check-in) with trusted individuals when in unfamiliar or doubtful situations adds an extra layer of safety. The uncertainty factor is 0.5 due to the risks in interactions and situations I might find myself in, especially because I am still in college. The resulting risk is calculated at \$562.50.

3. Availability > Low-Mid: My availability, both physically and mentally, holds a value of \$1,000,000. If I am impaired or face a life-threatening situation, my ability to function normally gets compromised, impacting several facets of my personal and professional life. For example, the property under my name back home, information that only I am aware of which could cost my family, etc. With an ARO of 0.1, preventive measures include being constantly aware of my surroundings, holding life and health insurance policies, and always keeping emergency contacts informed. The uncertainty factor for this stands at 0.15, considering various unpredictable life events. The risk posed from this perspective is \$28,750. Beyond the controls already in place, a contingency plan and specified beneficiaries are recognized as crucial to ensure a smooth transition of responsibilities and financial assets.

Hardware

ASSET NAME: Personal Laptop 1

DESCRIPTION: MacBook Pro

1. Confidentiality > Mid: The potential risk of unwanted disclosure from my laptop is valued at \$25,000. This represents the financial implications and potential damages from the leakage of confidential data due to spyware. A key concern is unauthorized parties gaining insights into my personal, financial, or work-related information, this could lead to fines, costs to replace banking/tax information, restore/recover stolen identity. My current measures against such threats include a high degree of alertness, avoiding suspicious links, employing a firewall, and using the Safari browser for sensitive tasks, which offers enhanced privacy features. ARO of encountering such a threat is estimated to be 0.1. The uncertainty associated with this threat, given the evolving nature of spyware and cyber-attacks, is marked at 0.15. This puts the risk value at \$718.75. To bolster the defenses against such a threat, I recognize the potential value of incorporating an advanced personal firewall and task specific device separation.

2. Integrity > Mid: The integrity of the data on my MacBook Pro holds a significant value of \$9,000. This includes pictures, videos, and media that holds personal value for me. I also use it for critical tasks daily. Any alteration, whether due to malware or data corruption, can have significant consequences. Keeping the device updated, ensuring that only trusted software is installed, and regular data backups are the primary preventive measures in place. An ARO of 0.1 is recognized for these types of threats, with an uncertainty factor of 0.15. The resultant risk stands at \$258.75. To further safeguard the integrity of my data, I deem the 3-2-1 data backup strategy – three total copies of data, two of which are locally stored on different mediums and one stored offsite – as an invaluable additional control.

3. Availability > High: The physical availability of my MacBook Pro is priced at \$4,000. Events like theft or damage to the device could severely impede my ability to function effectively in various capacities. Current measures to mitigate this risk include always being aware of my surroundings when the device is in use and having device insurance in the form of AppleCare+. The ARO for such physical threats is approximated at 0.15, with an uncertainty level of 0.5, given the unpredictability of such events. This results in a risk of \$225. Considering the criticality of the device, adding theft insurance to the preventive measures could further minimize potential losses.

Software

ASSET NAME: Instagram

DESCRIPTION: Social Media Account

1. Confidentiality > Low: This aspect pertains to the potential exposure of information shared on my Instagram but primarily the data collected by the application as well. This includes Personally Identifiable Information, Usage data, and more. Valued at \$9,500, this could translate into personal data leaks or hacks leading to consequences beyond the platform. While I ensure never to share or store confidential information on devices which enable easy sharing, there's a low ARO of 0.001. With an uncertainty level of 0.25, the risk comes out to be \$1.19. To further reinforce my protective measures, it might be important to maintain a separate device for sensitive data, periodically request the deletion of Personally Identifiable Information from the platform, and consistently audit permissions granted to third-party apps or services.

2. Integrity > Mid: Priced at \$100, this dimension focuses on the integrity of my online identity. If my account gets spoofed, it could tarnish my reputation and mislead my friends and followers. Using privacy controls and dual-factor authentication are my primary defense mechanisms. With an ARO set at 0.05 and an uncertainty factor of 0.5, the risk evaluates to \$0.75. To optimize my defense, conducting an audit of my privacy settings at regular intervals can ensure they align with the best practices.

3. Availability > Low: Valued similarly at \$100, this touches on my accessibility to the platform. In scenarios where a hacker locks me out of my own account, my online presence is directly affected. Countering such threats, I use a strong password combined with dual-factor authentication. With an ARO of 0.05 and an uncertainty level of 0.25, the risk is a manageable \$0.63. Further, I understand that I should periodically audit my login data, ensuring its complexity and uniqueness.

Data

ASSET NAME: External SSD (Solid State Drive)

DESCRIPTION: Important Backup

1. Confidentiality > High: The potential exposure or unauthorized access to the data within the SSD is estimated to have a financial impact of \$2,000. The primary threat is the theft of academic work, including personal data. The occurrence of this threat could lead to academic repercussions or misuse of personal data. While Disk Encryption acts as a primary control mechanism, the associated Annual Rate of Occurrence (ARO) is estimated at 0.05. Coupled with an uncertainty level of 0.15, the calculated risk is at \$28.75.

2. Integrity > High: Ensuring the intactness and authenticity of the academic work stored is paramount, and any compromise could jeopardize my academic integrity. The associated risk is again priced at \$2,000. The use of Disk Encryption is pivotal in ensuring that even if the device falls into the wrong hands, alterations to the data are thwarted. With an ARO set at 0.05 for threats compromising integrity and an uncertainty of 0.15, the resultant risk is \$28.75.

3. Availability > Low-Mid: Ensuring I can access my academic work when needed holds a value of \$150. While the potential loss or damage to the SSD could impede access, the impact of this is perceived to be on the lower side. To mitigate these risks, I ensure to handle the device with due care. However, potential threats to availability have a very low ARO, approximately 0.001. Paired with an uncertainty of 0.3, the risk comes out to a minuscule \$0.05. To further enhance my control measures, integrating a device tracker might offer real-time location tracking, potentially aiding in retrieval if lost.

Process

ASSET NAME: Class/Work Routine

DESCRIPTION: Fixed class & work schedule

1. Confidentiality > Low: This category covers the potential exposure of my routine leading to property theft. I've assigned a potential financial impact of \$8,000 to this. If one were to study my movements, it might make my property a prime target for property or data theft during predictable absences. To counteract such threats, I've put in place security systems like alarms and location trackers on critical devices. Given an ARO of 0.05, coupled with an uncertainty level of 0.5, the calculated risk equates to \$60. To further solidify this defense, integrating video surveillance could act as a deterrent to potential trespassers.

2. Integrity > Mid: Valued at \$10,000, this aspect touches on the risk of my academic and personal reputation being tarnished, potentially through identity theft. If my fixed routine is exploited, miscreants might leverage the predictability to misrepresent or misuse my personal data. Current countermeasures include Secure Access protocols and dedicated bank services, presenting a control effectiveness that results in a risk value of \$75.

3. Availability > Low-Mid: This dimension, with an assigned value of \$30,000, highlights the potential risks associated with information theft due to the predictability of my routine. An adversary could exploit my regular class or work timings to access stored data during my predictable absences. However, all crucial data is stored securely, either in safe locations or on safeguarded devices, giving a resulting risk of \$225. An effective measure to bolster this security could be the drafting and adherence to a self-regulated data retention policy.

Categorization and Analysis of Google Chrome as a System

Often overlooked as a simple software, a browser is a whole lot more in today's world. It is a gateway to the online world that we all are a part of. Be it from banking or simply using social media to keep up with your friends. All the way to working/learning from home, we have seen a rise in these activities even more so after the Covid-19 Pandemic. In my case, I use Google Chrome as my primary browser and since I use it for many tasks this acts as a system for me including data transfer, communication, media consumption, education, work and more.

Categorization: Confidentiality > High, Integrity > High, Availability > High

Sub-Assets:

- Browser itself as a software
- Extensions and plugins
- Passwords and Auto-fill data
- Cached data or Session information

- Sync Data across devices

Functionality:

I use all my school, personal, and work email webapps on Chrome. I also use OneDrive to store and transfer data, websites for personal shopping, make digital transactions, access classes and create academic work. From maps for information about places to visit to quick google searches, I heavily use this multi-faceted system.

Confidentiality: I avoid using this for sensitive data transfer, including my personal/work emails from which I generally avoid sending or retaining sensitive information. This helps me avoid unwanted interception of information. I also keep Chrome updated and only install extensions from trusted and reviewed developers. All of which helps me keep a minimal impact.

Integrity: This being critical, I pay special attention to it. Recently, I learned about “Linus Tech Tips”, a prominent tech YouTube channel which got hacked and all their content started getting replaced with Tesla live streams. This was because an employee had clicked on a phish through which the Google Chrome Session was stolen. This affected their image and fans did not know what was happening for a day. Similarly, if I am not vigilant of malicious rerouting, phishing links, etc. I could lose a lot of my critical data.

Availability: While a lot of my daily tasks are done on Google Chrome, like class work, grocery shopping, etc. I am not entirely dependent on Chrome; I can do these tasks on Safari as well, but I know there will be times when occasionally I need to use Chrome. So, the impact is lower but not completely non-existent.

Vulnerabilities/threats to the system:

- Spyware
- Malware
- Data Corruption
- Hacked/ Spoofed
- Data Leaks

Controls in place:

- Using trusted web applications
- Installing trusted extensions
- Not storing sensitive passwords
- Secure access to the system and key information/accounts
- Task & Device Segregation

Most Vulnerable aspect: Confidentiality which can be compromised by spyware or phishing attacks.

Additional Controls Needed:

- Safe Link Proxy (this could limit my own legitimate use as well)
- Extension Audit Schedule

For my digital landscape, it is evident that due to the multi-faceted and complex nature of information in today's world. There are various exposure points, ranging from personal data on social media like Instagram to widespread use of browsers like Google Chrome. While assets such as my external SSD carry concentrated, physical hazards centered on data security and integrity, software platforms magnify these risks across virtual domains. My Google Chrome usage, for example, exposes vulnerabilities that extend beyond the device on which it is installed, affecting my online interactions and data footprint. Meanwhile, traditional platforms, such as my class and job routines, pose hazards that combine the virtual and actual worlds perfectly. Many of these hazards are mitigated by the sophisticated protection mechanisms in place, which range from disk encryption to stringent browser security protocols. Regardless, the ever-changing nature of technology and the risks linked with it suggest that this is not the case.

Overall, while my present risk posture is well-defended against many modern dangers, the fluidity of the digital domain needs constant awareness, frequent reassessments, and adaptive defensive measures to assure long-term security. With this assessment, I discovered how to quantify the value of my assets, threats, and a reasonable cost for protection or countermeasures. I also realized how much bigger my attack surface was and what additional controls I needed to protect myself.

As previously said, it is my belief that asset inventory and assessment, which was formerly considered a "nice to have," has now become a need. From local coffee shops to government agencies, these exercises can help determine the attack surface and efficiently minimize it.

Excel file attached for inventory and risk assessment matrix.